COMPTIA PENTEST+ · PT0-003 · DOMAIN 4.0

4.7 — Wireless Attacks & Tools

Wireless attacks almost never win alone — they win in **chains**. This guide organizes 8 attack techniques and 6 tools around one spine: **passive recon → forcing function → association → harvest**. Learn the spine and every scenario question becomes "which link is this?"

8 attack techniques · **6** tools · **5** attack chains · **Active vs Passive** is the #1 tested split · **Layer** of operation is #2

THE MENTAL MODEL

The Wireless Kill-Chain Spine

Every technique and tool in 4.7 plugs into one of four stages. Memorize the stages; slot the pieces.

Four stages, color-coded for the rest of this guide

Recon feeds the attack, the attack forces a reconnection, the reconnection creates an association you control, and control is where value is harvested.

1 · SEE passive recon → **2 · SHOVE** forcing function → **3 · SNARE** rogue association → **4 · SIPHON** harvest / crack

STAGE	WHAT HAPPENS	TECHNIQUES & TOOLS THAT LIVE HERE
1 · SEE	Find networks & map the RF world without touching the target	Wardriving · WiGLE.net · Kismet · InSSIDer
2 · SHOVE	Break connectivity to force predictable client behavior	Deauthentication · Signal jamming
3 · SNARE	Stand up a lookalike AP the client associates to	Evil twin · WiFi-Pumpkin · airbase-ng

4 · SIPHON	Collect credentials or crack captured material	`Captive portal` `WPAD` `aircrack-ng`

Two techniques sit off to the side because they attack the *device*, not the *connection*: `Protocol fuzzing` (break the firmware) and `Packet crafting` (the raw skill that *builds* deauth, evil-twin, and fuzzing frames). And `WPS PIN attack` is its own lane — it recovers the PSK directly, no evil twin needed.

SPINE MNEMONIC

See · Shove · Snare · Siphon

"The four S's." SEE passively, SHOVE them off, SNARE them onto your AP, SIPHON the value. If a question describes a step, ask which S it is — the answer's tool falls out of the stage.

PART 1 · WIRELESS ATTACKS

01 Eight Techniques

Each card: what it is · the picture that makes it stick · the exam tells woven in.

1 Wardriving

SEE · PASSIVE

What: Moving through an area with a wireless adapter in `monitor mode` to detect & log APs from their `beacon frames` — collecting SSID, BSSID, channel, encryption type, and signal strength (`dBm`, closer to 0 = stronger). GPS is logged alongside to build a map.

PICTURE IT

A census taker driving the block writing down every house's name, address, and whether the door is locked — *never knocking*. Purely passive: not one packet is sent to the target.

EXAM TELLS

- **"Passive"** + **"no packets sent"** → wardriving is the answer, and it's the **first step** of the workflow.
- Variations: **warwalking** (on foot), **warflying** (drone), **warchalking** (marking symbols).
- Reveals **rogue APs** and **legacy encryption** (WEP, WPA/TKIP) instantly.
- Hidden SSIDs "leak" via **client probe traffic** — a recurring trap answer.

2 Evil Twin Attack

SNARE · ACTIVE

What: A rogue AP that `clones the SSID` (optionally the BSSID via MAC spoofing) of a real network. Broadcasts at higher power / closer range so clients prefer it — or are forced onto it via deauth. Once associated, the attacker is an `on-path adversary`.

PICTURE IT

A fake toll booth painted like the real one, planted a few feet before it and lit up brighter. Cars pull into *yours* — and now every car passes through your hands. It defeats encryption by attacking the *trust* layer, not the crypto.

Why clients connect: devices auto-join known networks from their `Preferred Network List` — no user action needed.

EXAM TELLS

- **Evil twin ≠ rogue AP.** Rogue AP can be accidental/unauthorized; evil twin is **intentional impersonation** for interception.
- Most powerful when chained with **deauth** (force reconnect) + **captive portal** (harvest).
- After association: SSL stripping, DNS manipulation, session hijack, downgrade — all "on-path" verbs.

3 Signal Jamming

SHOVE · ACTIVE

What: Flooding a frequency band (`2.4 / 5 GHz`) with `RF interference` at the `physical layer`, denying service. In pentesting it's rarely the goal — it's a `forcing function` that drives reconnection events (and pushes clients toward an evil twin).

PICTURE IT

Blasting an air horn in a crowded room so no one can hear each other — everyone stops, then tries to reconnect the moment it's quiet. Loud and broad, not surgical.

LEGAL FLAG

The **FCC prohibits** jammers that interfere with authorized comms — even in an authorized test, jamming may need explicit legal review. The exam tests this awareness.

EXAM TELLS — JAMMING VS DEAUTH

- Jamming = **physical/RF layer**, broad & loud. Deauth = **management-frame layer**, targeted & surgical.
- Any mention of **"legal restriction / FCC"** on a wireless disruption → jamming.

4 Protocol Fuzzing

DEVICE · ACTIVE

What: Sending `malformed 802.11 frames` (invalid fields, out-of-bounds lengths, bad flag combos) to probe `implementation weaknesses` in firmware/drivers — not the protocol's crypto. Outcomes: crash, lockup, parsing errors, or `memory corruption`.

PICTURE IT

Feeding a vending machine bent coins, foreign currency, and folded bills to see if it jams or spits out free product. You're testing how the *machine* mishandles garbage — not whether the money is real.

Why management frames: they're processed `pre-association` — a device can be crashed by a malformed beacon *before any connection exists*.

EXAM TELLS

- **"Implementation / firmware / driver weakness"** (not cryptographic) → fuzzing. A device can implement WPA3 perfectly and still crash on a bad frame.
- Three 802.11 frame types: **management** (beacons/probes/auth), **control** (ACK/RTS/CTS), **data** (payload). Fuzzing targets management first.
- Must be **explicitly authorized** — it's disruptive.

5 Packet Crafting

MECHANISM · ACTIVE

What: Manually constructing packets/frames byte-by-byte with custom headers, flags, and payloads. It's the `mechanism` under deauth (crafted mgmt frames), evil twin (crafted beacons), and fuzzing (crafted malformed frames).

PICTURE IT

Instead of buying a letter, you write your own — choosing the return address, the wording, even folding it to slip under a specific door. Total control over every byte.

FOUR STAGES MNEMONIC

Assemble · Edit · Send · Analyze

"AESA." Build it → tweak fields → inject it → watch the response.

EXAM TELLS

- Packet crafting = **active** (creates traffic). Packet **capture** = **passive** (observes). Classic paired distractor.
- Uses: **bypass firewall filters**, **test IDS/IPS**, **fragment** to evade signatures, **spoof source** addresses, PoC without full exploit.

6 Deauthentication

SHOVE · ACTIVE

What: Spoofed 802.11 `deauth management frames` forcibly disconnect a client. In WPA2 & earlier these frames are `unauthenticated` — any device can forge one. The client reconnects, generating a `four-way handshake` you capture for `offline cracking`.

PICTURE IT

Yelling "the meeting's cancelled!" in a voice that sounds like the boss. Everyone packs up and immediately tries to rejoin — and you record the door-code they punch on the way back in.

EXAM TELLS

- **Targeted** (client MAC) vs **broadcast** (all clients at once).
- Purpose #1: **force handshake capture**. Purpose #2: **drive clients to an evil twin**.
- **WPA3 / Protected Management Frames (PMF)** signs mgmt frames → mitigates deauth. Know this evolution.
- Detected by **WIDS** watching for abnormal deauth-frame volume.

7 Captive Portal

SIPHON · SOCIAL

What: A web page deployed on the evil twin that intercepts outbound traffic and demands "authentication" before internet access. Exploits `user conditioning` — people expect portals in hotels, airports, cafés and interact without scrutiny.

PICTURE IT

A fake receptionist desk in a lobby you've walked through a hundred times. "Just sign in here" — and because that's exactly what the real desk always asked, you hand over your badge without a second thought.

EXAM TELLS

- Captive portals are **web apps** — can carry input-validation, session, auth-bypass, and command-injection flaws (escalation beyond creds).
- vs standard phishing: the user is **already in an authenticate-me context** → far less suspicion.
- Legit portals often gate on **MAC address tracking** → bypass by **MAC spoofing** an observed authorized address.
- Must keep internet working to avoid suspicion.

8 WPS PIN Attack

DIRECT PSK · ACTIVE

What: Wi-Fi Protected Setup lets devices join via an 8-digit PIN. The flaw: the router validates the PIN in `two independent halves`, and the 8th digit is a checksum — so the search space collapses from 10^8 (100 million) to `~11,000` attempts. Recovers the WPA2 PSK **regardless of password strength**.

PICTURE IT

A combination lock that beeps "correct!" after the first three digits, then again after the next three — so you crack each half separately instead of the whole. A 10,000-lever safe reduced to two tiny dials.

VARIANT	TYPE	EXPLOITS
Online brute force (Reaver-style)	Active — PINs sent to AP	Beats **lockouts** by slowing / pausing / racing the attack
Pixie Dust	**Offline**	**Weak RNG** — NULL or timestamp seed makes the WPS exchange crackable offline (much faster)

EXAM TELLS

- **~11,000 combinations** and **"two halves"** = signature phrases for the WPS PIN flaw.
- **Pixie Dust** = **offline + poor random number generation**. Online = direct PIN attempts.
- Push-button method needs **physical access**; supported on **Windows/Android**, not macOS/iOS/some Linux.
- Remediation: **disable WPS**.

PART 2 · WIRELESS ATTACK TOOLS

02 Six Tools

The exam's favorite tool question: "*which tool for this purpose?*" — anchored on recon timing (pre-engagement vs on-site) and active vs passive.

9 WPAD (Web Proxy Auto-Discovery)

SIPHON · PROTOCOL

What: A `protocol` (not a tool) where clients auto-query the network for a `PAC file` to configure proxy settings. On an evil twin you control the network — so you

answer with a **malicious PAC file** that routes all traffic through your proxy. Fires **automatically, no user interaction**.

PICTURE IT

A new employee asks "where do I send my mail?" and you — controlling the mailroom — say "through me." Every letter now crosses your desk, and they never even knew they asked.

EXAM TELLS

- WPAD is a **protocol/attack surface**, not a standalone tool. Natural extension of the **evil twin chain**.
- Especially effective in **corporate environments** where proxies are standard.

10 WiFi-Pumpkin (wifipumpkin3)

SNARE · FRAMEWORK

What: An all-in-one `rogue AP / evil twin framework`. Bundles AP creation, captive portal, DNS spoofing, traffic capture, credential logging, and proxy integration into one workflow — automating the AP + DHCP + DNS + web + capture juggling.

PICTURE IT

A food truck that comes with the grill, register, menu boards, and cash drawer already installed — you park and serve, instead of assembling a kitchen from parts.

EXAM TELLS

- The **delivery mechanism** for evil twin + captive portal + WPAD + on-path, at scale.
- Manages victims by keeping internet working so they stay connected.

11 Aircrack-ng Suite

FULL LIFECYCLE

What: A `suite` (not one app) covering the whole WPA workflow: monitor → capture → deauth → handshake → offline crack.

COMPONENT	JOB	STAGE
airmon-ng	Enable monitor mode	SEE
airodump-ng	Passive capture & AP/client discovery	SEE
aireplay-ng	Packet injection — deauth, fake auth	SHOVE
airbase-ng	Create fake / evil-twin AP	SNARE

aircrack-ng	Offline WEP/WPA key recovery	SIPHON

```
# the canonical 5-step workflow
airmon-ng start wlan0 # monitor mode
airodump-ng -c [ch] --bssid [AP] -w cap wlan0mon # target + save
aireplay-ng -0 1 -a [AP] -c [client] wlan0mon # deauth → handshake
aircrack-ng -w wordlist cap.cap # offline crack
```

EXAM TELLS

- **WEP** cracking needs enough captured **IVs** — no dictionary. **WPA/WPA2** needs the **four-way handshake + wordlist**.
- Cracking is **offline** → stealthy, no further network contact. Needs an adapter supporting **monitor mode + injection**.

12 WiGLE.net

SEE · PASSIVE OSINT

What: A crowd-sourced `database` of APs mapped to GPS coordinates (SSID, BSSID, encryption, first/last-seen). Pure `OSINT` for `pre-engagement` recon — research a target's wireless footprint **before setting foot on-site**.

PICTURE IT

Street View, but for Wi-Fi — a public atlas built from everyone else's wardrives. You scout the neighborhood from your desk.

EXAM TELLS

- **Passive, no target interaction, historical** data. Great for **SSID reuse** across sites and **remote-location** research.
- Limitation: crowd-sourced → may be outdated / incomplete.

13 InSSIDer

SEE · ON-SITE LIVE

What: A `real-time` Wi-Fi analyzer showing live SSID, BSSID, channel, dBm signal, band, and security type for every detectable network. The on-site complement to WiGLE.

PICTURE IT

A live radar sweep on your screen while standing in the parking lot — WiGLE told you what *was* here; InSSIDer shows what's here *right now*.

EXAM TELLS

- Two headline uses: **channel scanning** (find the AP's channel for Aircrack targeting) and **signal-strength analysis** (positioning + tuning an evil twin's power).

- Contrast pairing: **WiGLE = historical/off-site**; **InSSIDer = live/on-site**.

14 Kismet

SEE · PASSIVE STEALTH

What: A `passive` detector / sniffer / WIDS that **transmits nothing** — it only listens. Discovers `hidden SSIDs` from client probe/association frames, maps `client↔AP associations`, and detects `Wi-Fi, Bluetooth, Zigbee`. Exports `PCAP` for Wireshark/Aircrack-ng.

PICTURE IT

A silent bat in the rafters — it never makes a sound of its own, just listens to everyone else's echoes and maps the whole room. Undetectable because it never pings.

EXAM TELLS

- **"Stealth / detection avoidance / transmits nothing"** on a scanner → Kismet (vs InSSIDer's active scan).
- Key concept: **hidden SSIDs aren't hidden** — probe traffic gives them away.
- Doubles as a **WIDS** (detects deauth floods, SSID spoofing) and sees **multi-protocol** IoT.

THE ONE-LINE PAYOFF

Two Signature Chains to Burn In

If you remember nothing else, remember these two flows — they answer most scenario questions.

CROWN JEWEL — WPA2 CREDENTIAL RECOVERY

deauth → forced reconnect → **four-way handshake capture** → **offline crack** (aircrack-ng + wordlist)

CROWN JEWEL — CREDENTIAL HARVEST

evil twin → **captive portal** → user submits creds → (optionally **WPAD** to siphon proxied traffic)

MEMORY AIDS

03 Mnemonic Vault

HOOK	UNPACKS TO	NAILS DOWN
SEE · SHOVE · SNARE · SIPHON	Recon → forcing function → rogue association → harvest	The whole domain's spine
"AESA"	**A**ssemble · **E**dit · **S**end · **A**nalyze	Packet crafting's 4 stages
"Two halves = 11K"	Split PIN validation collapses 100M → ~11,000	WPS PIN flaw
"Pixie = poor RNG, offline"	NULL/timestamp seed → offline WPS crack	Pixie Dust vs online brute force
"PMF protects"	Protected Management Frames (WPA3) sign mgmt frames	Deauth mitigation
"Historical / Live / Silent"	**WiGLE** historical · **InSSIDer** live · **Kismet** silent	The 3 recon tools, disambiguated
"mon-dump-replay-crack + base"	air**mon** · air**odump** · air**eplay** · air**crack** (+ air**base** = evil twin)	Aircrack-ng components
"Physical vs Frame"	Jamming = RF/physical · Deauth = mgmt-frame	The two SHOVE techniques

DON'T MIX THESE UP

04 Confusables Cram

These are the pairs the exam deliberately blurs. Read the verdict line for the one distinguishing word.

Evil Twin

Deliberate impersonation of a real SSID to intercept clients.

Rogue AP

Any unauthorized AP — could be an employee's accidental hotspot.

Verdict: an evil twin **is** a rogue AP, but a rogue AP isn't always an evil twin. The word is **intent to impersonate**.

Signal Jamming

Deauthentication

RF interference at the **physical layer**. Broad, loud, FCC-restricted.	Spoofed **management frames**. Targeted, surgical, PMF-mitigable.

Verdict: both disrupt connectivity — the split is the **layer**. "FCC/legal" → jamming. "Handshake capture" → deauth.

Protocol Fuzzing	**Deauth / Evil Twin**
Attacks **implementation** (firmware/driver) with malformed frames.	Attack **protocol design** weaknesses (unauthenticated frames, trust).

Verdict: fuzzing finds bugs a **perfect WPA3 implementation could still have**. "Crash/lockup/memory corruption" → fuzzing.

Packet Crafting	**Packet Capture (sniffing)**
Active — *creates* new frames and injects them.	**Passive** — *observes* existing traffic.

Verdict: craft = write, capture = read. Crafting **generates** traffic (detectable); capture is silent.

Online WPS (Reaver)	**Pixie Dust**
Sends PIN guesses **to the AP**; fights lockouts by throttling.	**Offline**; exploits **weak RNG** (NULL/timestamp seed). Faster.

Verdict: "poor random number generation" and "offline" → **Pixie Dust**, every time.

InSSIDer	**Kismet**
Active live scan; on-site; channel + signal strength.	**Passive**, transmits nothing; stealth; hidden SSIDs; multi-protocol; WIDS.

Verdict: "minimize detection / stealth" → **Kismet**. "Tune the evil twin's channel/power" → **InSSIDer**.

WiGLE.net	**InSSIDer / Kismet**
Off-site, historical OSINT database — before the engagement.	**On-site, real-time** — once you're within RF range.

Verdict: "before arriving / remote location / historical" → **WiGLE**. Live in the lot → InSSIDer/Kismet.

PART 3 · CORRELATING CONCEPTS

05 The Five Attack Chains

Scenario questions describe a chain and ask for the sequence or the missing link. Each chain below carries its exam trigger.

Chain 1 — WPA/WPA2 Credential Recovery

> Trigger: "recover the WPA2 passphrase — what's the correct sequence of steps?"

WiGLE pre-engagement SSID/BSSID › **InSSIDer** channel + signal › **Kismet** who's connected › **airmon/airodump** monitor + target › **aireplay** deauth → handshake › **aircrack** offline dictionary

Chain 2 — Evil Twin with Credential Harvesting

> Trigger: "harvest corporate credentials from wireless clients — which combination?"

Wardrive/InSSIDer ID SSID/BSSID/ch › **WiFi-Pumpkin** rogue AP clones SSID › **aireplay deauth** push off real AP › **Captive portal** harvest creds › **WPAD** siphon proxied traffic

Chain 3 — Passive Wireless Reconnaissance

> Trigger: "gather maximum info while minimizing detection risk — what approach?"

WiGLE pre-engagement › **Kismet** hidden SSIDs, associations › **InSSIDer** channel/signal/security › **Wardriving** geographic footprint

Chain 4 — WPS Attack

> Trigger: "target AP has WPS enabled — what attack, and what's the outcome?"

InSSIDer/airodump find WPS-enabled AP › **Online brute (Reaver)** ~11K PINs › **OR Pixie Dust** offline, weak RNG › **PSK recovered** regardless of complexity

Chain 5 — Protocol Fuzzing & Packet Crafting

> Trigger: "test whether an AP properly validates 802.11 management frames — what technique?"

Kismet/airodump — ID AP + clients › **Packet crafting** — build malformed mgmt frames › **Protocol fuzzing** — inject, test stability ›

Observe — crash / lockup / corruption

PART 4 · EXAM REFLEXES

06 Scenario Red-Flag Decoder

See the phrase on the left → answer on the right. These are the trigger words graders lean on.

IF THE QUESTION SAYS…	REACH FOR
"passive," "no packets sent," "first step," map the footprint	**Wardriving** / WiGLE
"minimize detection," "stealth," "transmits nothing," hidden SSIDs	**Kismet**
"before arriving on-site," "remote location," "historical"	**WiGLE.net**
"identify the channel," "signal strength," "on-site," tune the twin	**InSSIDer**
"clone the SSID," "on-path adversary," stronger signal, trust layer	**Evil twin** (+ WiFi-Pumpkin)
"force reconnection," "capture the handshake," disconnect a client	**Deauthentication**
"RF interference," "physical layer," "FCC/legal restriction"	**Signal jamming**
"malformed frames," "firmware/driver," crash/lockup/memory corruption	**Protocol fuzzing**
"~11,000 combinations," "two halves," WPS enabled	**WPS PIN attack**
"offline," "poor random number generation," NULL/timestamp seed	**Pixie Dust**

"login page on the rogue AP," "users expect to authenticate"	**Captive portal**
"auto-configure proxy," "PAC file," redirect corporate traffic	**WPAD**
"crack WPA offline," "four-way handshake + wordlist," suite	**Aircrack-ng**
"signs management frames," "PMF," resists deauth	**WPA3** (mitigation)
"detects deauth floods / SSID spoofing"	**WIDS** (incl. Kismet)

07 Four Reflexes for the Exam

REFLEX	HOW TO APPLY IT
Active vs Passive	**Passive:** Kismet, WiGLE, wardriving, InSSIDer's passive scan. **Active:** deauth, packet crafting, WPS brute force, evil-twin deployment. Detection risk lives here.
Layer of operation	**Physical/RF:** jamming. **802.11 mgmt-frame:** deauth, evil twin, fuzzing. **Network/app:** WPAD, captive-portal harvesting.
Tool ↔ purpose	Match the *one* job: find networks off-site → WiGLE; channel/signal on-site → InSSIDer; stealth + hidden SSID → Kismet; crack WPA → Aircrack-ng; evil twin + portal → WiFi-Pumpkin; redirect proxy → WPAD.
Mitigations	**WPA3/PMF** → deauth. **Disable WPS** → PIN/Pixie. **Strong unique PSK** → offline cracking. **WIDS** → deauth floods + evil twins.

⚡ Night-Before Cheat Strip

THE SPINE

- **SEE → SHOVE → SNARE → SIPHON** — the four S's.
- Recon feeds attack, attack forces reconnect, reconnect = association you control, control = harvest.

THE TWO CROWN CHAINS

- deauth → handshake → **offline crack**.
- evil twin → captive portal → **creds** (± WPAD).

RECON TRIO, ONE WORD EACH

- **WiGLE** = historical / off-site.
- **InSSIDer** = live / channel + signal.
- **Kismet** = silent / hidden SSID / WIDS.

NUMBERS & NAMES TO LOCK

- WPS = **~11,000**, two-half validation.
- **Pixie Dust** = offline + weak RNG.
- **PMF (WPA3)** kills deauth.

LAYER SPLITS

- Jamming = **physical/RF** (FCC).
- Deauth = **mgmt frame** (surgical).
- Fuzzing = **implementation**, not crypto.

AIRCRACK-NG MEMBERS

- **airmon** mode · **airodump** capture · **aireplay** inject · **aircrack** crack · **airbase** evil twin.
- WEP = IVs; WPA = handshake + wordlist.